

# Taller de Testing — Técnicas de caja negra

|                      |                                                                                                                                                                            |
|----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Proyecto bajo prueba | CodeByMike — <code>codebymike.tech</code>                                                                                                                                  |
| Módulos              | Portal de clientes ( <code>/portal</code> : autenticación, facturas, cuenta) y Cobros de campo ( <code>/cobrar</code> → <code>/c/[code]</code> → <code>/mis-pagos</code> ) |
| Stack                | Astro 7 (SSR) · Turso/libSQL · Drizzle · Tailwind 4 · Vercel                                                                                                               |
| Técnicas aplicadas   | Casos de prueba · Escenarios · Particiones de equivalencia · Valores límite (BVA) · Pruebas exploratorias · Trazabilidad                                                   |
| Responsable          | Mike (@mikerb95)                                                                                                                                                           |
| Fecha de ejecución   | 26–27 de julio de 2026                                                                                                                                                     |

## Entorno de pruebas

Todos los casos se ejecutaron contra una instancia **local y desechable**, nunca contra producción: los casos escriben (pagos, sesiones, bloqueos de cuenta) y no deben tocar datos reales ni gastar cuota de Turso.

| Elemento         | Valor                                                                                   |
|------------------|-----------------------------------------------------------------------------------------|
| Servidor         | <code>astro dev</code> en <code>http://localhost:4399</code> (Node 22.22.3)             |
| Base de datos    | libSQL en archivo temporal, sembrada con <code>scripts/seed-demo.mjs</code>             |
| Pasarela de pago | Proveedor <code>mock</code> ( <code>PAYMENTS_MOCK_ENABLED=true</code> ); sin Wompi real |
| Navegador        | Chrome (Chromium), viewport 1512×787                                                    |
| Correo / ntify   | Desactivados (no-op silencioso: faltan las env vars)                                    |

## Datos de prueba sembrados

| Usuario                                   | Cliente                    | Estado                                          | Contraseña                                                            |
|-------------------------------------------|----------------------------|-------------------------------------------------|-----------------------------------------------------------------------|
| <code>ana.torres@altiplano.test</code>    | Cafetería Altiplano (id 1) | activo                                          | Altiplano2026 (cambiada a <code>abcdefghil</code> al ejecutar CDE-01) |
| <code>carlos.ruiz@otrocliente.test</code> | Clínica Dental Nova (id 2) | activo                                          | OtroCliente2026                                                       |
| <code>inactivo@altiplano.test</code>      | Cafetería Altiplano (id 1) | desactivado                                     | Inactivo2026                                                          |
| <code>bloqueo@altiplano.test</code>       | Cafetería Altiplano (id 1) | activo (cuenta quemada para el caso de bloqueo) | Altiplano2026                                                         |

## TESTING-CODEBYMIKE

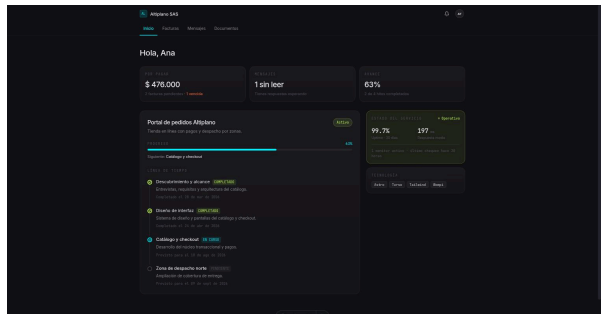
| Cobro (código corto) | Monto     | Estado inicial  | Vencimiento             |
|----------------------|-----------|-----------------|-------------------------|
| MN5TW3               | \$195.000 | creado          | +72 h (vigente)         |
| AB3K9F               | \$150.000 | creado          | +72 h (vigente)         |
| XY7MQ2               | \$80.000  | creado          | -2 h ( <b>vencido</b> ) |
| PK4RT8               | \$320.000 | <b>aprobado</b> | +48 h                   |

Teléfono del pagador en los cuatro cobros: +57 310 464 1228.

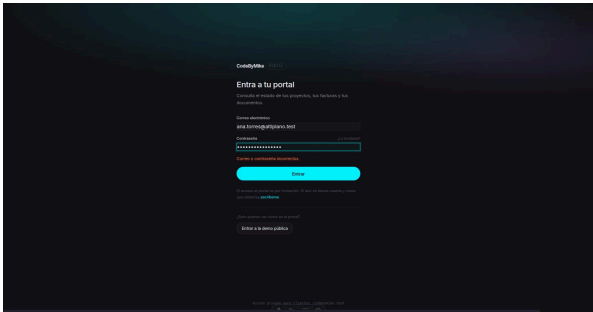
### Reglas de negocio verificadas en el código (fuente de los oráculos)

| Regla                                                                                   | Dónde vive                                         |
|-----------------------------------------------------------------------------------------|----------------------------------------------------|
| Contraseña: 10–200 caracteres, con al menos una letra y un dígito                       | <code>src/lib/portal/passwords.ts:34</code>        |
| Bloqueo de cuenta a los 10 intentos fallidos, durante 15 minutos                        | <code>src/lib/portal/login.ts:21</code>            |
| Monto de un pago: entero entre 100.000 y 500.000.000 centavos COP                       | <code>src/pages/api/payments/checkout.ts:20</code> |
| Código corto: 6 caracteres del alfabeto ABCDEFGHJKMNPQRSTUVWXYZ23456789 (sin 0/O/1/I/L) | <code>src/lib/cobros-codes.ts</code>               |
| Teléfono: normalizable a E.164 (+[1–9] y 8–15 dígitos)                                  | <code>src/lib/phone.ts</code>                      |
| <code>/mis-pagos</code> : 5 consultas por IP y hora                                     | <code>src/pages/api/mis-pagos/lookup.ts:28</code>  |
| El <code>clientId</code> sale siempre de la sesión, nunca del request                   | <code>src/lib/portal/session.ts</code>             |

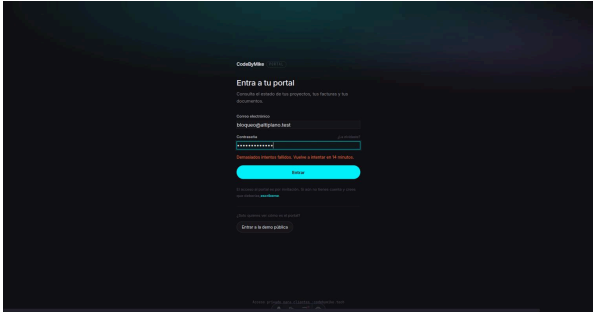
## Casos de Prueba

|                              |                                                                                                                                                                                                                             |
|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                           | TC-01                                                                                                                                                                                                                       |
| Módulo/Función               | Portal — Autenticación · Login con credenciales válidas                                                                                                                                                                     |
| Objetivo                     | Validar que un usuario de un cliente con portal habilitado inicia sesión y llega a su panel.                                                                                                                                |
| Precondiciones               | Usuario <code>active</code> con contraseña definida; su cliente tiene <code>portal_enabled = 1</code> ; sin sesión previa.                                                                                                  |
| Datos de prueba              | Correo: <code>ana.torres@altiplano.test</code> · Contraseña: <code>Altiplano2026</code>                                                                                                                                     |
| Pasos (numerados)            | 1. Abrir <code>/portal/login</code> .<br>2. Escribir el correo.<br>3. Escribir la contraseña.<br>4. Presionar «Entrar».                                                                                                     |
| Oráculo (resultado esperado) | HTTP 200 con cookie <code>portal_session</code> ( <code>HttpOnly, SameSite=Lax, Max-Age=2592000</code> ). Redirección a <code>/portal</code> con el saludo «Hola, Ana» y los KPI del cliente (por pagar, mensajes, avance). |
| Resultado obtenido           | ✅ Conforme. Cookie emitida; panel de Cafetería Altiplano con «\$ 476.000 por pagar», «1 sin leer», «63% de avance».                                                                                                         |
| Veredicto                    | <b>PASA</b>                                                                                                                                                                                                                 |
| Evidencia (archivo)          | <br>TC-01-login-valido-dashboard.jpg                                                                                                    |

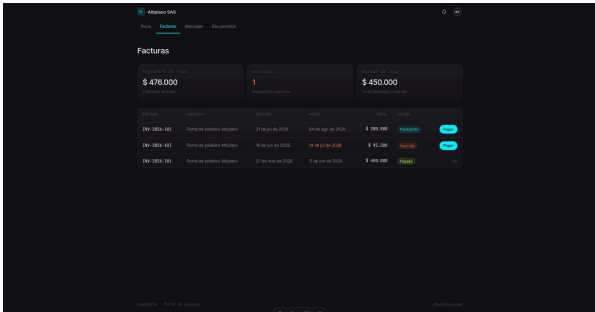
## TESTING-CODEBYMIKE

|                              |                                                                                                                                                                                               |
|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                           | TC-02                                                                                                                                                                                         |
| Módulo/Función               | Portal — Autenticación · Login con credenciales inválidas                                                                                                                                     |
| Objetivo                     | Verificar que un fallo de credenciales no revela si la cuenta existe (mensaje único).                                                                                                         |
| Precondiciones               | La cuenta <code>ana.torres@altiplano.test</code> existe; <code>nadie@nada.test</code> no existe.                                                                                              |
| Datos de prueba              | (a) correo existente + <code>claveIncorrecta1</code> · (b) <code>nadie@nada.test</code> + <code>Altiplano2026</code>                                                                          |
| Pasos (numerados)            | 1. Abrir <code>/portal/login</code> .<br>2. Escribir el correo y una contraseña incorrecta.<br>3. Presionar «Entrar».<br>4. Repetir con un correo inexistente.                                |
| Oráculo (resultado esperado) | En <b>ambos</b> casos, el mismo texto: «Correo o contraseña incorrectos.» Sin cookie de sesión. La latencia debe ser comparable (se calcula un script de relleno para la cuenta inexistente). |
| Resultado obtenido           | ✅ Conforme. Los dos caminos devuelven el mismo mensaje, palabra por palabra.                                                                                                                  |
| Veredicto                    | <b>PASA</b>                                                                                                                                                                                   |
| Evidencia (archivo)          |  <p>TC-02-login-credenciales-invalidas.jpg</p>                                                            |

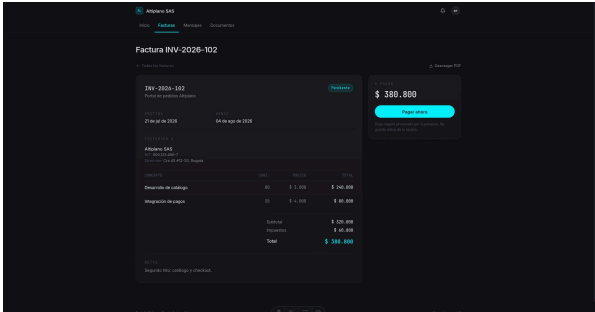
## TESTING-CODEBYMIKE

|                              |                                                                                                                                                                                                                                   |
|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                           | TC-03                                                                                                                                                                                                                             |
| Módulo/Función               | Portal — Autenticación · Bloqueo temporal por fuerza bruta                                                                                                                                                                        |
| Objetivo                     | Verificar que la cuenta se bloquea 15 minutos al décimo intento fallido, aunque el atacante cambie de IP.                                                                                                                         |
| Precondiciones               | Cuenta <code>bloqueo@altiplano.test</code> activa, con el contador de fallos en 0.                                                                                                                                                |
| Datos de prueba              | 10 intentos con <code>claveIncorrecta1</code> , <b>cada uno desde una IP distinta</b> ; luego un intento con la contraseña correcta <code>Altiplano2026</code> .                                                                  |
| Pasos (numerados)            | 1. Enviar 10 intentos fallidos variando <code>x-forwarded-for</code> .<br>2. Intentar entrar con la contraseña <b>correcta</b> .                                                                                                  |
| Oráculo (resultado esperado) | Intentos 1-9: «Correo o contraseña incorrectos.» Intento 10: «Demasiados intentos fallidos. Vuelve a intentar en 15 minutos.» El intento posterior con la contraseña correcta <b>también</b> se rechaza mientras dure el bloqueo. |
| Resultado obtenido           | ✅ Conforme. El bloqueo saltó exactamente en el intento 10 y resistió la contraseña correcta («...en 14 minutos», el contador decrece). Cambiar de IP no evita el bloqueo: el contador va contra la cuenta, no contra la IP.       |
| Veredicto                    | <b>PASA</b>                                                                                                                                                                                                                       |
| Evidencia (archivo)          |  <p>TC-03-bloqueo-tras-10-intentos.jpg</p>                                                                                                    |

## TESTING-CODEBYMIKE

|                              |                                                                                                                                                                                                                                                  |
|------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                           | TC-04                                                                                                                                                                                                                                            |
| Módulo/Función               | Portal — Facturas · Visualización del listado                                                                                                                                                                                                    |
| Objetivo                     | Verificar que el cliente ve sus facturas con estado y totales coherentes con los KPI.                                                                                                                                                            |
| Precondiciones               | Sesión activa de <code>ana.torres@altiplano.test</code> ; el cliente 1 tiene 3 facturas sembradas.                                                                                                                                               |
| Datos de prueba              | INV-2026-101 (\$450.000, pagada) · INV-2026-102 (\$380.800, pendiente) · INV-2026-103 (\$95.200, vencida)                                                                                                                                        |
| Pasos (numerados)            | <ol style="list-style-type: none"> <li>1. Iniciar sesión.</li> <li>2. Ir a la pestaña «Facturas».</li> <li>3. Contrastar los KPI de la cabecera con la suma de las filas.</li> </ol>                                                             |
| Oráculo (resultado esperado) | Las 3 facturas listadas con su estado. «Pendiente de pago» = $380.800 + 95.200 =$ <b>\$476.000</b> . «Vencidas» = <b>1</b> . «Pagado en 2026» = <b>\$450.000</b> . La factura vencida marca la fecha en rojo. Solo las abiertas ofrecen «Pagar». |
| Resultado obtenido           | ✅ Conforme. Los tres agregados cuadran con las filas; la pagada solo ofrece «Ver».                                                                                                                                                               |
| Veredicto                    | <b>PASA</b>                                                                                                                                                                                                                                      |
| Evidencia (archivo)          |  <p>TC-04-facturas-listado.jpg</p>                                                                                                                           |

## TESTING-CODEBYMIKE

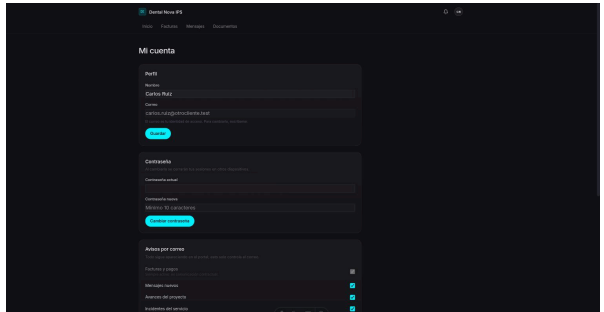
|                              |                                                                                                                                                                                                                                                         |
|------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                           | TC-05                                                                                                                                                                                                                                                   |
| Módulo/Función               | Portal — Facturas · Detalle y descarga del PDF                                                                                                                                                                                                          |
| Objetivo                     | Verificar que el detalle desglosa los conceptos y que el PDF se descarga como adjunto y no se cachea.                                                                                                                                                   |
| Precondiciones               | Sesión activa de Ana; factura id 2 (INV-2026-102) del cliente 1.                                                                                                                                                                                        |
| Datos de prueba              | Desarrollo de catálogo: $80 \times \$3.000 = \$240.000$<br>· Integración de pagos: $20 \times \$4.000 = \$80.000$                                                                                                                                       |
| Pasos (numerados)            | 1. Abrir <code>/portal/facturas/2</code> .<br>2. Verificar el desglose y el total.<br>3. Pulsar «Descargar PDF».                                                                                                                                        |
| Oráculo (resultado esperado) | Subtotal \$320.000 + impuestos \$60.800 = total <b>\$380.800</b> , igual al bloque «A pagar». La descarga responde 200, content-type: application/pdf, content-disposition: attachment; filename="INV-2026-102.pdf" y cache-control: no-store, private. |
| Resultado obtenido           | ✅ Conforme. PDF real de 2.123 bytes con cabecera <code>%PDF-1.7</code> ; todas las cabeceras esperadas presentes.                                                                                                                                       |
| Veredicto                    | <b>PASA</b>                                                                                                                                                                                                                                             |
| Evidencia (archivo)          |  <p>TC-05-factura-detalle-pdf.jpg</p>                                                                                                                               |

## TESTING-CODEBYMIKE

|                              |                                                                                                                                                                                                                                                                                                                               |
|------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                           | TC-06                                                                                                                                                                                                                                                                                                                         |
| Módulo/Función               | Portal — Aislamiento entre clientes                                                                                                                                                                                                                                                                                           |
| Objetivo                     | Verificar que un cliente <b>no</b> puede leer una factura de otro cliente conociendo su id. Un fallo aquí no degrada una función: expone los datos de un cliente a otro.                                                                                                                                                      |
| Precondiciones               | Dos clientes con portal habilitado; la factura id 2 pertenece al cliente 1.                                                                                                                                                                                                                                                   |
| Datos de prueba              | Sesión de <code>carlos.ruiz@otrocliente.test</code> (cliente 2) pidiendo la factura id 2.                                                                                                                                                                                                                                     |
| Pasos (numerados)            | <ol style="list-style-type: none"> <li>1. Iniciar sesión como Carlos.</li> <li>2. Navegar directamente a <code>/portal/facturas/2</code>.</li> <li>3. Pedir además <code>/api/portal/facturas/2/pdf</code>.</li> <li>4. Repetir como Ana (dueña) para descartar un falso positivo.</li> <li>5. Repetir sin sesión.</li> </ol> |
| Oráculo (resultado esperado) | Carlos: <b>404</b> en la página y <b>404</b> en el PDF (no 403: un 403 confirmaría que el recurso existe). Ana: <b>200</b> . Sin sesión: <b>302</b> a <code>/portal/login?next=%2Fportal%2Ffacturas%2F2</code> .                                                                                                              |
| Resultado obtenido           | ✅ Conforme en los cuatro caminos.                                                                                                                                                                                                                                                                                             |
| Veredicto                    | <b>PASA</b>                                                                                                                                                                                                                                                                                                                   |
| Evidencia (archivo)          |  <p>TC-06-aislamiento-entre-clientes-404.jpg</p>                                                                                                                                                                                          |



## TESTING-CODEBYMIKE

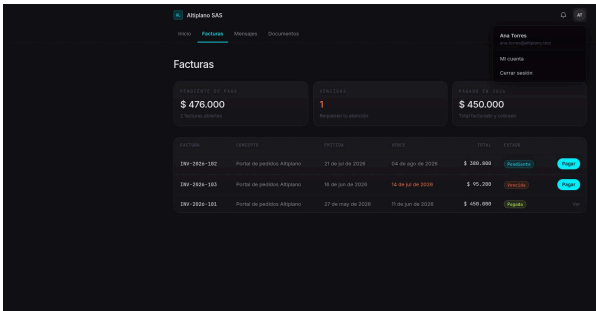
|                              |                                                                                                                                                                                                                                                                                                                                                 |
|------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                           | TC-07                                                                                                                                                                                                                                                                                                                                           |
| Módulo/Función               | Portal — Cuenta · Cambio de contraseña                                                                                                                                                                                                                                                                                                          |
| Objetivo                     | Verificar que la contraseña nueva se valida (longitud y composición) y que se exige la actual aunque ya haya sesión.                                                                                                                                                                                                                            |
| Precondiciones               | Sesión activa; se conoce la contraseña actual.                                                                                                                                                                                                                                                                                                  |
| Datos de prueba              | Actual: Altiplano2026 · Nuevas: abcdefgh1 (9), abcdefghij (10 sin dígitos), abcdefghil (10 válida)                                                                                                                                                                                                                                              |
| Pasos (numerados)            | <ol style="list-style-type: none"> <li>1. Abrir /portal/cuenta.</li> <li>2. Escribir la contraseña actual y una nueva de 9 caracteres.</li> <li>3. Pulsar «Cambiar contraseña».</li> <li>4. Repetir con una de 10 caracteres sin dígitos.</li> <li>5. Repetir con una contraseña actual incorrecta y una nueva válida.</li> </ol>               |
| Oráculo (resultado esperado) | 9 caracteres → «La contraseña debe tener al menos 10 caracteres.» · 10 sin dígitos → «La contraseña debe combinar letras y números.» · Nueva válida con actual incorrecta → «La contraseña actual no es correcta.» (la validación de formato corre <b>antes</b> de tocar la BD). Éxito → «Contraseña cambiada. Las demás sesiones se cerraron.» |
| Resultado obtenido           | <input checked="" type="checkbox"/> Conforme en los tres mensajes.<br><b>Observación:</b> el aviso se auto-oculta a los 4 s (ver BUG-04).                                                                                                                                                                                                       |
| Veredicto                    | <b>PASA con observación</b>                                                                                                                                                                                                                                                                                                                     |
| Evidencia (archivo)          |  <p>TC-07-cambio-contrasena-formulario.jpg</p>                                                                                                                                                                                                              |

## TESTING-CODEBYMIKE

|                              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                           | TC-08                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Módulo/Función               | Portal — Autenticación · Cerrar sesión                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Objetivo                     | Verificar que «Cerrar sesión» revoca la sesión y devuelve al login.                                                                                                                                                                                                                                                                                                                                                                                                                |
| Precondiciones               | Sesión activa de <code>ana.torres@altiplano.test</code> .                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Datos de prueba              | —                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Pasos (numerados)            | <ol style="list-style-type: none"> <li>1. Iniciar sesión.</li> <li>2. Abrir el menú del avatar (arriba a la derecha).</li> <li>3. Pulsar «Cerrar sesión».</li> <li>4. Navegar a <code>/portal</code>.</li> </ol>                                                                                                                                                                                                                                                                   |
| Oráculo (resultado esperado) | Redirección 302 a <code>/portal/login?m=session-closed</code> , cookie borrada y fila de <code>portal_sessions</code> eliminada. Al volver a <code>/portal</code> debe pedir login.                                                                                                                                                                                                                                                                                                |
| Resultado obtenido           | <p>❌ <b>No conforme.</b> El navegador muestra una página en blanco con el texto <code>Cross-site POST form submissions are forbidden</code>. La sesión <b>no</b> se cierra: al volver a <code>/portal</code> el usuario sigue dentro como Ana. Reproducido 2 de 2 veces en un flujo limpio. El mismo <code>POST</code> con cabecera <code>Origin</code> explícita sí devuelve 302 y cierra la sesión, así que el endpoint funciona: falla la petición que emite el formulario.</p> |
| Veredicto                    | <b>FALLA → BUG-01</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                              |

TESTING-CODEBYMIKE

Evidencia (archivo)



TC-08-menu-cerrar-sesion.jpg

•

El usuario puede hacer modificaciones en los formularios.

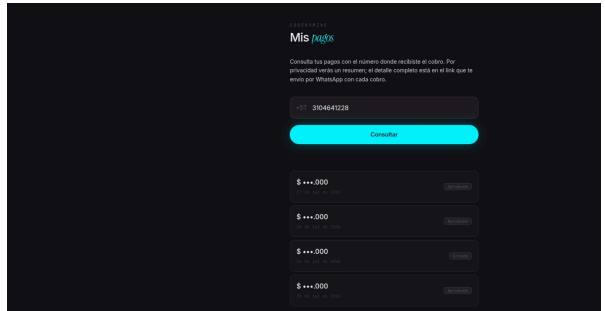
BUG-01-logout-csrf.jpg

## TESTING-CODEBYMIKE

|                              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                           | TC-09                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Módulo/Función               | Cobros de campo — Pago desde el link corto<br>/c/[code]                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Objetivo                     | Verificar el ciclo completo de un cobro: link vigente → pago → estado terminal, y que los links vencido y ya pagado no permiten cobrar de nuevo.                                                                                                                                                                                                                                                                                                                                                                      |
| Precondiciones               | Cobros MN5TW3 (vigente), XY7MQ2 (vencido) y PK4RT8 (aprobado) en la base.                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Datos de prueba              | MN5TW3 = \$195.000, «Soporte y ajustes de octubre», vence en 3 días.                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Pasos (numerados)            | <ol style="list-style-type: none"> <li>1. Abrir /c/MN5TW3 (sin sesión: es un link público).</li> <li>2. Verificar monto, concepto y vencimiento.</li> <li>3. Pulsar «Pagar».</li> <li>4. Confirmar el estado en la base.</li> <li>5. Repetir el pago (doble clic).</li> <li>6. Abrir /c/XY7MQ2 y /c/PK4RT8.</li> </ol>                                                                                                                                                                                                |
| Oráculo (resultado esperado) | <p>Paso 2: «\$195.000», concepto y «vence en 3 días»; el monto se firma en el servidor y el link no puede alterarlo. Paso 3: página «¡Gracias! Pago recibido». Paso 4: estado <code>approved</code>. Paso 5: <b>idempotente</b> — el segundo intento no aplica nada (<code>applied:false</code>) y el estado sigue en <code>approved</code>. Paso 6: «Este link venció» y «Este cobro ya fue pagado»; sus endpoints de checkout devuelven <code>{"status":"expired"}</code> y <code>{"status":"approved"}</code>.</p> |
| Resultado obtenido           |  Conforme en los seis pasos. El pago pasó <code>created</code> → <code>pending</code> → <code>approved</code> y el reintento quedó registrado como duplicado sin efecto.                                                                                                                                                                                                                                                           |
| Veredicto                    | <b>PASA</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |

TC-09c-cobro-link-vencido.jpg

## TESTING-CODEBYMIKE

|                              |                                                                                                                                                                                                                                                                                                                                                |
|------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                           | TC-10                                                                                                                                                                                                                                                                                                                                          |
| Módulo/Función               | Cobros de campo — Histórico público /mis-pagos                                                                                                                                                                                                                                                                                                 |
| Objetivo                     | Verificar que consultar por teléfono devuelve datos <b>enmascarados</b> (un teléfono no es una credencial) y que la consulta está limitada por IP.                                                                                                                                                                                             |
| Precondiciones               | 4 cobros asociados a +573104641228.                                                                                                                                                                                                                                                                                                            |
| Datos de prueba              | 3104641228 • 310 464 1228 • +573104641228 • 1234 • abc                                                                                                                                                                                                                                                                                         |
| Pasos (numerados)            | <ol style="list-style-type: none"> <li>1. Abrir /mis-pagos.</li> <li>2. Escribir el número y pulsar «Consultar».</li> <li>3. Repetir con las variantes de formato.</li> <li>4. Probar entradas inválidas.</li> <li>5. Repetir la consulta 6 veces desde la misma IP.</li> </ol>                                                                |
| Oráculo (resultado esperado) | Se listan los pagos con fecha, estado y <b>monto enmascarado</b> (\$ •••.000): nunca el monto completo, nunca el concepto, nunca el teléfono. Las tres variantes de formato dan el mismo resultado (se normalizan a E.164). Entradas inválidas → «número inválido». La 6. <sup>a</sup> consulta desde la misma IP → «demasiadas consultas...». |
| Resultado obtenido           | <p>✓ Conforme. 4 pagos con monto enmascarado y estados «Aprobado»/«Creado»; el límite saltó exactamente en la 6.<sup>a</sup> consulta. <b>Observación:</b> las entradas inválidas también consumen cuota (ver BUG-03).</p>                                                                                                                     |
| Veredicto                    | <b>PASA con observación</b>                                                                                                                                                                                                                                                                                                                    |
| Evidencia (archivo)          |  <p>TC-10-mis-pagos-historico-enmascarado.jpg</p>                                                                                                                                                                                                          |

# TESTING-CODEBYMIKE

# Escenario

[illegible]

## TESTING-CODEBYMIKE

### Escenario 2

|                     |                                                                                                                                                                                                                                                                                                                                                                                                           |
|---------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                  | ESC-02                                                                                                                                                                                                                                                                                                                                                                                                    |
| Nombre              | Link de cobro, pago, idempotencia, caducidad e histórico                                                                                                                                                                                                                                                                                                                                                  |
| Objetivo            | Validar que un cobro enviado por WhatsApp se paga una sola vez, que caduca, y que el pagador puede consultar su historial sin exponer datos a terceros.                                                                                                                                                                                                                                                   |
| Precondiciones      | Cobros MN5TW3 (vigente), XY7MQ2 (vencido), PK4RT8 (pagado) asociados a +573104641228.                                                                                                                                                                                                                                                                                                                     |
| Pasos (numerados)   | <ol style="list-style-type: none"><li>1. Abrir /c/MN5TW3 sin sesión y verificar monto y vencimiento. <b>(TC-09)</b></li><li>2. Pagar.</li><li>3. Reintentar el pago (doble clic).</li><li>4. Abrir /c/XY7MQ2 (vencido).</li><li>5. Abrir /c/PK4RT8 (ya pagado).</li><li>6. Ir a /mis-pagos y consultar por el teléfono. <b>(TC-10)</b></li><li>7. Consultar 6 veces seguidas desde la misma IP.</li></ol> |
| Oráculo de salida   | El cobro vigente se paga una vez y queda approved; el reintento no duplica el cargo; el vencido y el pagado se niegan con su propio mensaje; el histórico muestra 4 pagos con montos enmascarados; la 6. <sup>a</sup> consulta se corta por límite.                                                                                                                                                       |
| Resultado obtenido  |  <b>Conforme en los siete pasos.</b> El estado recorrió created → pending → approved, el reintento quedó marcado como duplicado sin aplicar, y el histórico nunca reveló montos completos.                                                                                                                             |
| Veredicto           | <b>PASA</b>                                                                                                                                                                                                                                                                                                                                                                                               |
| Evidencia (archivo) | TC-09a..., TC-09b..., TC-09c..., TC-10...                                                                                                                                                                                                                                                                                                                                                                 |



## Particiones de equivalencia

| Operación / Módulo                                               | Regla / Restricción                                                                                                       | Clases válidas                                                                       | Clases inválidas                                                                                           | Representantes                                                                                             | Oráculo esperado                                                                                                                                   |
|------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Definir contraseña</b><br>(/portal/cuenta, invitación, reset) | 10–200 caracteres, con al menos una letra <b>y</b> un dígito                                                              | V1: longitud 10–200 con letra y dígito                                               | I1: longitud < 10<br>I2: longitud > 200<br>I3: sin dígitos<br>I4: sin letras                               | V1 Altiplano2026 (13)<br>I1 abcdefgh1 (9)<br>I2 200×a+12 (201)<br>I3 abcdefghij (10)<br>I4 1234567890 (10) | V1 se acepta. I1 → «al menos 10 caracteres». I2 → «demasiado larga (máx. 200)». I3 e I4 → «debe combinar letras y números».                        |
| <b>Monto de un cobro</b><br>(amountCents)                        | Entero entre 100.000 y 500.000.000 centavos COP (\$1.000 – \$5.000.000)                                                   | V1: entero dentro del rango                                                          | I1: menor al mínimo<br>I2: mayor al máximo<br>I3: no entero<br>I4: no numérico                             | V1 15000000<br>I1 99999<br>I2 500000001<br>I3 100000.5<br>I4 "abc"                                         | V1 crea el pago (201/200 con referencia). I1–I4 → 400 con «amountCents debe ser un entero entre 100000 y 500000000».                               |
| <b>Teléfono</b> (/mis-pagos)                                     | Normalizable a E.164: móvil colombiano de 10 dígitos que empieza por 3, o cualquier número con + explícito (8–15 dígitos) | V1: 10 dígitos empezando por 3<br>V2: el mismo con separadores<br>V3: con +57 o 0057 | I1: menos de 10 dígitos<br>I2: con letras<br>I3: local que no empieza por 3<br>I4: vacío                   | V1 3104641228<br>V2 310 464 1228<br>V3 +573104641228<br>I1 310464122<br>I2 abc<br>I3 2104641228<br>I4 ""   | V1–V3 se normalizan al mismo +573104641228 y devuelven el <b>mismo</b> histórico. I1–I4 → 400 «número inválido».                                   |
| <b>Código corto</b><br>(/c/ [code])                              | Exactamente 6 caracteres del alfabeto ABCDEFGHJKLMNPQRSTUVWXYZ23456789 (sin 0, O, 1, I, L) <b>y</b> existente en la base  | V1: 6 caracteres del alfabeto que existen                                            | I1: longitud ≠ 6<br>I2: carácter fuera del alfabeto<br>I3: minúsculas<br>I4: forma válida pero inexistente | V1 MN5TW3<br>I1 ABC<br>I2 AB0K9F<br>I3 ab3k9f<br>I4 ZZZZZZ                                                 | V1 muestra el cobro. I1–I4 → 404 «Cobro no encontrado», sin distinguir entre «mal formado» e «inexistente» (no dar pistas a quien sondea códigos). |

**Nota sobre I3 (minúsculas):** el alfabeto excluye 0/O/1/I/L precisamente porque el código *se dicta por teléfono y se teclea a mano*. Rechazar las minúsculas contradice ese propósito → registrado como **BUG-02**.

## TESTING-CODEBYMIKE

### Casos derivados por equivalencia

| ID     | Operación                      | Precondiciones                            | Datos                                               | Pasos                                                                | Oráculo (esperado)                                                                                                                       | Resultado                             |
|--------|--------------------------------|-------------------------------------------|-----------------------------------------------------|----------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------|
| CDE-01 | Definir contraseña — clase V1  | Sesión activa, contraseña actual conocida | Actual = Altiplano2026 · Nueva = abcdefghil (10)    | 1. /portal/cuenta 2. Escribir actual y nueva 3. «Cambiar contraseña» | { "ok": true } y «Contraseña cambiada. Las demás sesiones se cerraron.» Después: la nueva contraseña entra (200) y la vieja es rechazada | ✓ PASA — verificados los tres efectos |
| CDE-02 | Definir contraseña — clase I1  | Ídem                                      | Nueva = abcdefghl (9)                               | Ídem                                                                 | «La contraseña debe tener al menos 10 caracteres.»                                                                                       | ✓ PASA                                |
| CDE-03 | Definir contraseña — clase I3  | Ídem                                      | Nueva = abcdefghij (10, sin dígitos)                | Ídem                                                                 | «La contraseña debe combinar letras y números.»                                                                                          | ✓ PASA                                |
| CDE-04 | Crear pago — clase V1          | Endpoint público disponible               | amountCents = 15000000, clave de idempotencia única | POST /api/payments/checkout                                          | 200/201 con reference y estado created                                                                                                   | ✓ PASA                                |
| CDE-05 | Crear pago — clase I3          | Ídem                                      | amountCents = 100000.5                              | Ídem                                                                 | 400 «debe ser un entero entre 100000 y 500000000»                                                                                        | ✓ PASA                                |
| CDE-06 | Consultar histórico — clase V2 | 4 cobros con ese teléfono                 | 310 464 1228                                        | 1. /mis-pagos 2. Consultar                                           | Mismo histórico que +573104641228, con montos enmascarados                                                                               | ✓ PASA                                |
| CDE-07 | Consultar histórico — clase I1 | Ídem                                      | 310464122 (9 dígitos)                               | Ídem                                                                 | 400 «número inválido»                                                                                                                    | ✓ PASA                                |
| CDE-08 | Abrir cobro — clase I2         | Cobro AB3K9F existe                       | AB0K9F (contiene un 0)                              | Abrir /c/AB0K9F                                                      | 404 «Cobro no encontrado»                                                                                                                | ✓ PASA                                |
| CDE-09 | Abrir cobro — clase I3         | Cobro AB3K9F existe                       | ab3k9f (minúsculas)                                 | Abrir /c/ab3k9f                                                      | Esperado por diseño: el cobro se abre (el código se dicta y se teclea a mano)                                                            | ✗ FALLA → BUG-02 (devuelve 404)       |

### Valores límite

| Parámetro / Límite              | Valores a probar (min-1, min, min+1, max-1, max, max+1)                                                    | Oráculo esperado                                                                                               | Notas                                                                                                                                                                                                                                                                      |
|---------------------------------|------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Longitud de contraseña (10-200) | 9 = abcdefghl<br>10 = abcdefghil<br>11 = abcdefghijl<br>199 = 197×a+12<br>200 = 198×a+12<br>201 = 199×a+12 | 9 y 201 → <b>FALLA</b> con el mensaje de longitud.<br>10, 11, 199, 200 → <b>PASA</b> la validación de formato. | Todas las pruebas llevan una contraseña actual deliberadamente incorrecta: si el valor supera la validación de formato, el sistema responde «La contraseña actual no es correcta», lo que <b>prueba</b> que pasó el filtro de longitud sin cambiar el estado de la cuenta. |

## TESTING-CODEBYMIKE

| Parámetro / Límite                                          | Valores a probar<br>(min-1, min, min+1,<br>max-1, max, max+1)             | Oráculo esperado                                                                                  | Notas                                                                                                                                        |
|-------------------------------------------------------------|---------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Monto del cobro en centavos</b><br>(100.000-500.000.000) | 99.999<br>100.000<br>100.001<br>499.999.999<br>500.000.000<br>500.000.001 | 99.999 y 500.000.001 → <b>FALLA</b> (400).<br>Los cuatro intermedios → <b>PASA</b> (pago creado). | El máximo equivale a \$5.000.000 COP. Un monto no entero (100000.5) también se rechaza: el tipo es tan límite como el rango.                 |
| <b>Intentos fallidos de login</b> (bloqueo en el 10)        | 9<br>10<br>11                                                             | 9 → mensaje genérico, cuenta usable.<br>10 → bloqueo de 15 min.<br>11 → sigue bloqueada.          | Verificado además que en el estado bloqueado <b>la contraseña correcta también se rechaza</b> : el bloqueo no se puede saltar acertando.     |
| <b>Consultas a /mis-pagos por IP y hora</b> (límite 5)      | 4<br>5<br>6                                                               | 4 y 5 → responden el histórico.<br>6 → 429<br>«demasiadas consultas».                             | El corte cae exactamente entre la 5. <sup>a</sup> y la 6. <sup>a</sup> . Ver BUG-03: las consultas con número inválido también gastan cuota. |

## Casos Valores límite BVA

### Longitud de contraseña

| ID     | Operación                         | Precondiciones | Datos        | Pasos                                                                     | Oráculo (esperado)                               | Resultado |
|--------|-----------------------------------|----------------|--------------|---------------------------------------------------------------------------|--------------------------------------------------|-----------|
| BVA-01 | Definir contraseña de 9 (min-1)   | Sesión activa  | abcdefghijkl | 1. /portal/cuenta 2. Escribir la nueva contraseña 3. «Cambiar contraseña» | Rechazo: «al menos 10 caracteres»                | ✓ PASA    |
| BVA-02 | Definir contraseña de 10 (min)    | Sesión activa  | abcdefghijkl | Ídem                                                                      | Supera la validación de longitud                 | ✓ PASA    |
| BVA-03 | Definir contraseña de 11 (min+1)  | Sesión activa  | abcdefghijkl | Ídem                                                                      | Supera la validación de longitud                 | ✓ PASA    |
| BVA-04 | Definir contraseña de 199 (max-1) | Sesión activa  | 197×a + 12   | Ídem                                                                      | Supera la validación de longitud                 | ✓ PASA    |
| BVA-05 | Definir contraseña de 200 (max)   | Sesión activa  | 198×a + 12   | Ídem                                                                      | Supera la validación de longitud                 | ✓ PASA    |
| BVA-06 | Definir contraseña de 201 (max+1) | Sesión activa  | 199×a + 12   | Ídem                                                                      | Rechazo: «demasiado larga (máx. 200 caracteres)» | ✓ PASA    |

## TESTING-CODEBYMIKE

### Monto del cobro

| ID     | Operación                         | Precondiciones   | Datos                 | Pasos                                                             | Oráculo (esperado)                 | Resultado |
|--------|-----------------------------------|------------------|-----------------------|-------------------------------------------------------------------|------------------------------------|-----------|
| BVA-07 | Crear pago de 99.999 (min-1)      | Endpoint público | amountCents=99999     | POST<br>/api/payments/checkout<br>con clave de idempotencia única | 400 con el rango en el mensaje     | ✓ PASA    |
| BVA-08 | Crear pago de 100.000 (min)       | Ídem             | amountCents=100000    | Ídem                                                              | Pago creado,<br>status:<br>created | ✓ PASA    |
| BVA-09 | Crear pago de 100.001 (min+1)     | Ídem             | amountCents=100001    | Ídem                                                              | Pago creado                        | ✓ PASA    |
| BVA-10 | Crear pago de 499.999.999 (max-1) | Ídem             | amountCents=499999999 | Ídem                                                              | Pago creado                        | ✓ PASA    |
| BVA-11 | Crear pago de 500.000.000 (max)   | Ídem             | amountCents=500000000 | Ídem                                                              | Pago creado                        | ✓ PASA    |
| BVA-12 | Crear pago de 500.000.001 (max+1) | Ídem             | amountCents=500000001 | Ídem                                                              | 400 con el rango en el mensaje     | ✓ PASA    |

### Intentos de login y consultas del histórico

| ID     | Operación                                               | Precondiciones               | Datos            | Pasos                        | Oráculo (esperado)                                                                    | Resultado           |
|--------|---------------------------------------------------------|------------------------------|------------------|------------------------------|---------------------------------------------------------------------------------------|---------------------|
| BVA-13 | Noveno intento fallido (min-1 del bloqueo)              | Cuenta activa, contador en 8 | claveIncorrecta1 | Enviar el intento 9          | «Correo o contraseña incorrectos.», cuenta aún usable                                 | ✓ PASA              |
| BVA-14 | Décimo intento fallido (umbral)                         | Contador en 9                | claveIncorrecta1 | Enviar el intento 10         | «Demasiados intentos fallidos... 15 minutos.»                                         | ✓ PASA              |
| BVA-15 | Intento 11 con la contraseña <b>correcta</b> (umbral+1) | Cuenta bloqueada             | Altiplano2026    | Intentar entrar              | Sigue bloqueada; el acierto no levanta el bloqueo                                     | ✓ PASA              |
| BVA-16 | Quinta consulta del histórico (max)                     | IP sin consultas previas     | 3104641228       | Consultar 5 veces            | Las 5 responden el histórico                                                          | ✓ PASA              |
| BVA-17 | Sexta consulta (max+1)                                  | IP con 5 consultas           | 3104641228       | Consultar una vez más        | 429 «demasiadas consultas...»                                                         | ✓ PASA              |
| BVA-18 | Sexta consulta con número <b>inválido</b>               | IP con 5 consultas inválidas | abc              | Consultar 6 veces con basura | <i>Esperado:</i> la entrada inválida no debería gastar cuota de una consulta legítima | ✗ FALLA<br>→ BUG-03 |

## Chárter de prueba exploratoria

|                       |                                                                                                                                                                                                                                                                                                                                                                                              |
|-----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                    | CHR-01                                                                                                                                                                                                                                                                                                                                                                                       |
| Objetivo (charter)    | Explorar el ciclo de sesión del portal y el ciclo de vida de un cobro de campo, buscando estados en los que el sistema <b>diga una cosa y haga otra</b> : sesiones que parecen cerradas, links que parecen inválidos, cobros que se pudieran pagar dos veces.                                                                                                                                |
| Alcance / Áreas       | /portal/login, menú de sesión, /portal/cuenta, /portal/facturas/[id], /c/[code], /mis-pagos, y los endpoints que los alimentan.                                                                                                                                                                                                                                                              |
| Riesgos               | <ul style="list-style-type: none"> <li>· Que «Cerrar sesión» no cierre nada (equipo compartido).</li> <li>· Que un link vencido o ya pagado permita un segundo cargo.</li> <li>· Que un cliente vea datos de otro cambiando un id en la URL.</li> <li>· Que el histórico público filtre montos o teléfonos.</li> <li>· Que las defensas anti-abuso castiguen al usuario legítimo.</li> </ul> |
| Tiempo (time-box)     | 45 minutos                                                                                                                                                                                                                                                                                                                                                                                   |
| Criterio de cierre    | Se agota el tiempo, o se cubren las cinco áreas con al menos un intento de abuso por cada riesgo listado.                                                                                                                                                                                                                                                                                    |
| Evidencias requeridas | Captura de cada anomalía + petición reproducible (curl o pasos en la UI) + estado en la base de datos cuando el defecto sea de persistencia.                                                                                                                                                                                                                                                 |

## Notas de exploración

| Hora  | Acción                          | Datos                                         | Resultado observado                                             | Resultado esperado (oráculo) | Notas / Riesgos                                                                                    |
|-------|---------------------------------|-----------------------------------------------|-----------------------------------------------------------------|------------------------------|----------------------------------------------------------------------------------------------------|
| 18:24 | Login con la cuenta desactivada | inactivo@altiplano.test + contraseña correcta | «Tu acceso ha sido desactivado. Contacta con tu administrador.» | Mensaje distinto al genérico | <b>Correcto por diseño</b> , no es fuga: solo lo ve quien ya acertó la contraseña, o sea el dueño. |

## TESTING-CODEBYMIKE

| Hora  | Acción                                        | Datos                                      | Resultado observado                                                                           | Resultado esperado (oráculo)                                      | Notas / Riesgos                                                                                                      |
|-------|-----------------------------------------------|--------------------------------------------|-----------------------------------------------------------------------------------------------|-------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------|
| 18:27 | Login con correo en mayúsculas y con espacios | "<br>ANA.TORRES@Altiplano.TEST<br>"        | 200, entra normalmente                                                                        | El correo se normaliza (trim + minúsculas)                        | Sin defecto. Evita cuentas duplicadas por tecleo.                                                                    |
| 18:31 | Checkout sobre un link <b>vencido</b>         | POST<br>/api/c/XY7MQ2/checkout             | {"error":"este link venció","status":"expired"}                                               | El vencimiento se aplica también en la API, no solo en la vista   | Sin defecto: la validación no está solo en el HTML.                                                                  |
| 18:32 | Checkout sobre un cobro <b>ya aprobado</b>    | POST<br>/api/c/PK4RT8/checkout             | {"error":"este cobro ya fue pagado","status":"approved"}                                      | Estado terminal, no se puede recobrar                             | Sin defecto.                                                                                                         |
| 18:34 | Código corto en minúsculas                    | /c/ab3k9f                                  | 404 «Cobro no encontrado»                                                                     | Debería abrir el cobro: el código se dicta por teléfono           | <b>BUG-02.</b> El alfabeto excluye 0/O/1/I/L justo para que se pueda dictar; rechazar minúsculas anula ese esfuerzo. |
| 18:38 | 10 intentos fallidos desde 10 IP distintas    | bloqueo@altiplano.test                     | Bloqueo en el intento 10                                                                      | El contador va contra la cuenta, no contra la IP                  | Sin defecto. Un atacante distribuido no evade el bloqueo.                                                            |
| 18:41 | Doble pago del mismo cobro                    | pay_taller_mn5tw3 × 2                      | 2.º intento: applied:false, duplicate:true, estado sigue approved                             | Idempotente                                                       | Sin defecto: el doble clic del cliente no duplica el cargo.                                                          |
| 18:45 | Factura de otro cliente por id                | Carlos (cliente 2) →<br>/portal/facturas/2 | 404 en página y PDF                                                                           | 404, nunca 403                                                    | Sin defecto. El <code>clientId</code> viaja en el <code>WHERE</code> desde la sesión.                                |
| 18:47 | 6 consultas con número inválido               | abc × 6 desde una IP                       | La 6.ª: 429                                                                                   | La basura no debería gastar la cuota del usuario legítimo         | <b>BUG-03.</b> Cinco erratas al teclear dejan al cliente una hora sin poder consultar.                               |
| 18:52 | Cerrar sesión desde el menú                   | Sesión de Ana                              | Página en blanco: Cross-site POST form submissions are forbidden; la sesión <b>sigue viva</b> | 302 a<br>/portal/login?<br>m=session-<br>closed y cookie revocada | <b>BUG-01.</b> El más grave del taller: el cliente cree que salió y no salió.                                        |

## TESTING-CODEBYMIKE

| Hora  | Acción                    | Datos                                    | Resultado observado                                                                                          | Resultado esperado (oráculo)                | Notas / Riesgos                                                                                                            |
|-------|---------------------------|------------------------------------------|--------------------------------------------------------------------------------------------------------------|---------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| 18:55 | 404 dentro del portal     | Carlos → <code>/portal/facturas/2</code> | Se renderiza el 404 <b>público</b> del sitio de marketing, con la navegación comercial y el banner de idioma | Un 404 coherente con el contexto del portal | <b>BUG-05.</b> Cosmético, pero desorienta a un cliente autenticado.                                                        |
| 18:58 | Auditoría de dependencias | <code>npm audit</code>                   | 18 vulnerabilidades: 2 críticas, 9 altas, 6 moderadas, 1 baja                                                | 0 críticas y 0 altas                        | <b>BUG-06.</b> Incluye una crítica en <code>@auth/core</code> , que es justo la librería de autenticación del panel admin. |

## Reporte de defectos

El taller de referencia dejaba la matriz TC ↔ BUG sin una tabla de defectos que la respaldara. Aquí los defectos se listan primero, con pasos reproducibles, y la matriz solo cruza lo que efectivamente se encontró.

| ID     | Título                                                                       | Severidad    | Módulo                           | Detectado en                            | Estado  |
|--------|------------------------------------------------------------------------------|--------------|----------------------------------|-----------------------------------------|---------|
| BUG-01 | «Cerrar sesión» falla y la sesión permanece abierta                          | <b>Alta</b>  | Portal · Autenticación           | TC-08, ESC-01                           | Abierto |
| BUG-02 | El código corto de un cobro distingue mayúsculas de minúsculas               | <b>Media</b> | Cobros · <code>/c/[code]</code>  | CDE-09, exploratoria                    | Abierto |
| BUG-03 | Las consultas inválidas consumen la cuota horaria de <code>/mis-pagos</code> | Baja         | Cobros · <code>/mis-pagos</code> | BVA-18, TC-10                           | Abierto |
| BUG-04 | El mensaje de validación del cambio de contraseña se auto-oculta a los 4 s   | Baja         | Portal · Cuenta                  | TC-07                                   | Abierto |
| BUG-05 | Un 404 dentro del portal renderiza el 404 público del sitio de marketing     | Baja         | Portal · Navegación              | TC-06, exploratoria                     | Abierto |
| BUG-06 | 18 vulnerabilidades en dependencias (2 críticas, 9 altas)                    | <b>Alta</b>  | Transversal · Dependencias       | Exploratoria ( <code>npm audit</code> ) | Abierto |

### BUG-01 — «Cerrar sesión» falla y la sesión permanece abierta

- **Severidad:** Alta. No es solo un error visual: el cliente cree que cerró sesión y no la cerró. En un equipo prestado o compartido, el siguiente que abra el navegador entra a sus facturas.
- **Pasos para reproducir:**
  1. Iniciar sesión en `/portal/login`.
  2. Abrir el menú del avatar (arriba a la derecha).
  3. Pulsar «Cerrar sesión».
  4. Navegar a `/portal`.
- **Resultado obtenido:** paso 3 → página en blanco con el texto `Cross-site POST form submissions are forbidden`. Paso 4 → el panel carga con la sesión intacta.

## TESTING-CODEBYMIKE

- **Resultado esperado:** 302 a `/portal/login?m=session-closed`, cookie borrada y fila eliminada de `portal_sessions`.
- **Reproducibilidad:** 2 de 2 en Chrome sobre `astro dev`.
- **Análisis:** el endpoint funciona. El mismo `POST /api/portal/logout` con cabecera `Origin: http://localhost:4399` responde 302 y cierra la sesión; sin cabecera `Origin` responde 403. Es la comprobación de origen de Astro (`checkOrigin`) rechazando el envío del formulario de `src/layouts/PortalLayout.astro:126`.
- **Pendiente de verificar:** si el fallo se reproduce también en producción (HTTPS y dominio propio) o si es específico del servidor de desarrollo. La diferencia importa para priorizarlo, no para dudar del hallazgo.

### BUG-02 — El código corto distingue mayúsculas de minúsculas

- **Severidad:** Media. Afecta al camino feliz del cobro: el cliente que teclea el código a mano recibe «Cobro no encontrado» y concluye que el link no sirve.
- **Pasos:** abrir `/c/ab3k9f` existiendo el cobro `AB3K9F`.
- **Obtenido:** 404 «Cobro no encontrado». **Esperado:** el cobro se abre.
- **Por qué es un defecto y no una decisión:** el alfabeto del código excluye deliberadamente `0`, `o`, `1`, `I` y `L` porque —según el propio comentario de `src/lib/cobros-codes.ts`— «el código se dicta por teléfono y se teclea a mano». Rechazar las minúsculas contradice ese objetivo de diseño.
- **Sugerencia:** normalizar a mayúsculas antes de validar la forma.

### BUG-03 — Las consultas inválidas consumen la cuota horaria

- **Severidad:** Baja. **Pasos:** enviar 5 consultas con un número mal escrito desde la misma IP y luego una con el número correcto.
- **Obtenido:** la 6.<sup>a</sup> (la buena) recibe 429 y el cliente queda una hora sin poder consultar. **Esperado:** el límite debería contar consultas *válidas*, o al menos cobrar mucho menos por una entrada mal formada.
- **Análisis:** en `src/pages/api/mis-pagos/lookup.ts` el `enforceLimit` corre **antes** de parsear el cuerpo, así que una errata pesa igual que una consulta real. El límite existe para encarecer la enumeración de teléfonos; hoy también castiga al dueño del número.

### BUG-04 — El aviso de validación se auto-oculta a los 4 segundos

- **Severidad:** Baja. **Pasos:** en `/portal/cuenta`, intentar una contraseña de 9 caracteres y esperar 5 segundos.
- **Obtenido:** el mensaje «La contraseña debe tener al menos 10 caracteres» aparece y desaparece; el formulario queda con los campos llenos y sin explicación de por qué no pasó nada.
- **Esperado:** un error de validación debería persistir hasta que el usuario corrija el campo. El auto-ocultado tiene sentido para un «Guardado ✓», no para un rechazo.
- **Origen:** `setTimeout (... 4000)` en el helper `flash` de `src/pages/portal/cuenta.astro:239`.

### BUG-05 — El 404 del portal es el 404 del sitio público

- **Severidad:** Baja (cosmético / consistencia). **Pasos:** con sesión de portal, abrir `/portal/facturas/<id ajeno>`.
- **Obtenido:** el 404 público, con la navegación comercial («Diseño Web», «Contáctame», «Login») y el banner de cambio de idioma.



## TESTING-CODEBYMIKE

- **Esperado:** un 404 dentro del marco del portal, con la navegación del cliente y un enlace de vuelta a sus facturas.

### BUG-06 — Vulnerabilidades en dependencias

- **Severidad:** Alta. **Comando:** `npm audit`.
- **Obtenido:** 18 vulnerabilidades — **2 críticas**, 9 altas, 6 moderadas, 1 baja.
- **Las más relevantes:**

| Paquete                                                      | Severidad      | Problema                                                                                                 |
|--------------------------------------------------------------|----------------|----------------------------------------------------------------------------------------------------------|
| @auth/core                                                   | <b>Crítica</b> | <code>getToken()</code> lanza una excepción no capturada ante cabeceras <code>Bearer</code> mal formadas |
| path-to-regexp (vía @vercel/routing-utils y @astrojs/vercel) | Alta           | Genera expresiones regulares con backtracking (ReDoS)                                                    |
| brace-expansion                                              | Alta           | Un rango numérico grande derrota la protección <code>max</code> documentada contra DoS                   |
| fast-uri                                                     | Alta           | Confusión de host mediante una barra invertida literal como delimitador de autoridad                     |
| esbuild (vía drizzle-kit)                                    | Moderada       | Cualquier sitio web puede enviar peticiones al servidor de desarrollo y leer la respuesta                |

- **Nota:** la crítica de `@auth/core` afecta a la librería que autentica el panel de administración; conviene tratarla aparte del resto.

### Matriz de trazabilidad TC ↔ BUG

Cada **x** significa que **ese caso de prueba fue el que reveló ese defecto**. Las celdas vacías no son un olvido: significan que el caso ejecutó ese camino sin encontrar el defecto (o que no lo ejercita).

| TC \ BUG                                  | BUG-01 | BUG-02 | BUG-03 | BUG-04 | BUG-05 | BUG-06 |
|-------------------------------------------|--------|--------|--------|--------|--------|--------|
| TC-01 · Login válido                      |        |        |        |        |        |        |
| TC-02 · Login inválido                    |        |        |        |        |        |        |
| TC-03 · Bloqueo por fuerza bruta          |        |        |        |        |        |        |
| TC-04 · Listado de facturas               |        |        |        |        |        |        |
| TC-05 · Detalle y PDF                     |        |        |        |        |        |        |
| TC-06 · Aislamiento entre clientes        |        |        |        |        | x      |        |
| TC-07 · Cambio de contraseña              |        |        |        | x      |        |        |
| TC-08 · Cerrar sesión                     | x      |        |        |        |        |        |
| TC-09 · Pago desde <code>/c/[code]</code> |        |        |        |        |        |        |
| TC-10 · Histórico <code>/mis-pagos</code> |        |        | x      |        |        |        |
| CDE-09 · Código en minúsculas             |        | x      |        |        |        |        |
| BVA-18 · Cuota con entradas inválidas     |        |        | x      |        |        |        |
| ESC-01 · Ciclo del cliente                | x      |        |        | x      |        |        |

## TESTING-CODEBYMIKE

| TC \ BUG                 | BUG-01 | BUG-02 | BUG-03 | BUG-04 | BUG-05 | BUG-06 |
|--------------------------|--------|--------|--------|--------|--------|--------|
| ESC-02 · Ciclo del cobro |        |        | X      |        |        |        |
| CHR-01 · Exploratoria    | X      | X      | X      |        | X      | X      |

### Cobertura inversa (BUG → dónde se detectó primero)

| BUG    | Detectado primero en      | ¿Lo habría cazado una prueba automatizada existente?                                                                       |
|--------|---------------------------|----------------------------------------------------------------------------------------------------------------------------|
| BUG-01 | TC-08 (manual, navegador) | No. Los <code>e2e</code> de <code>e2e/portal.spec.ts</code> verifican el <i>gate</i> de sesión, no el cierre desde la UI.  |
| BUG-02 | CDE-09 (partición I3)     | No. <code>tests/cobros.test.ts</code> prueba <code>isValidShortCode</code> con el alfabeto en mayúsculas.                  |
| BUG-03 | BVA-18 (valor límite)     | No. El límite se prueba con entradas válidas.                                                                              |
| BUG-04 | TC-07                     | No. Es un comportamiento de la capa de presentación.                                                                       |
| BUG-05 | TC-06                     | No. El caso automatizado solo comprueba el código 404, no qué se renderiza.                                                |
| BUG-06 | Exploratoria              | Sí — <code>npm audit</code> ya corre en <code>security.yml</code> ; el hallazgo está en el panel del LAB pero sin atender. |

### Resumen de ejecución

| Métrica                                | Valor                                                        |
|----------------------------------------|--------------------------------------------------------------|
| Casos de prueba (TC)                   | 10 · <b>8 pasan</b> , 1 pasa con observación, <b>1 falla</b> |
| Escenarios (ESC)                       | 2 · 1 pasa, 1 falla parcialmente                             |
| Casos derivados por equivalencia (CDE) | 9 · 8 pasan, 1 falla                                         |
| Casos de valores límite (BVA)          | 18 · 17 pasan, 1 falla                                       |
| Chárter exploratorio                   | 1 · 12 notas registradas                                     |
| <b>Defectos encontrados</b>            | <b>6</b> — 2 de severidad alta, 1 media, 3 bajas             |

### Lectura de los resultados

Las reglas de negocio y las defensas están bien puestas: los cuatro límites numéricos (contraseña, monto, intentos, cuota) caen exactamente donde el código dice que caen, el aislamiento entre clientes resiste la manipulación de ids, y la idempotencia impide el doble cargo. Nada de eso falló.

Los defectos aparecieron **en los bordes**: no en la lógica de dominio sino en la capa que la conecta con la persona — el formulario que no envía, el código que no se puede teclear, el mensaje que se va antes de leerse, el límite que castiga al legítimo. Es un resultado típico de las técnicas de caja negra aplicadas sobre un sistema con buena cobertura unitaria: lo que las pruebas automatizadas no miran es justo lo que ve el usuario.

El más grave, BUG-01, ilustra por qué el oráculo no puede detenerse en «la pantalla cambió»: la pantalla cambió (a un error), pero el **estado** —la sesión en la base de datos— no. Sin el paso 4 del caso («volver a `/portal`») el defecto se habría clasificado como cosmético.